

Política de Segurança da Informação

TuboPlast

INDÚSTRIA DE TUBOS PLÁSTICOS

Conduzindo qualidade em cada metro



Histórico de Versões

Data	Versão	Descrição	Autor	Aprovado por
31/05/2026	1.0	<i>Emissão inicial da Política de Segurança da Informação</i>	Gestão da Segurança da Informação	Comitê Executivo
12/06/2026	2.0	<i>Emissão final da Política de Segurança da Informação</i>	Gestão da Segurança da Informação	Comitê Executivo

SUMÁRIO

1. INTRODUÇÃO	3
2. OBJETIVOS	4
3. TERMOS E DEFINIÇÕES	4
4. PRINCÍPIOS DA SEGURANÇA DA INFORMAÇÃO	5
5. PAPÉIS E RESPONSABILIDADES	6
6. VIOLAÇÕES E GRAU DE RESPONSABILIDADE	7
7. INVENTÁRIO DE ATIVOS	8
8. INVENTÁRIO DE ATIVOS CRÍTICOS	9
9. CONTEXTO ORGANIZACIONAL	10
10. CONTROLES DE SEGURANÇA DA INFORMAÇÃO	11
10.1. CONTROLE DE ACESSO FÍSICO	11
10.2. CONTROLE DE ACESSO LÓGICO	16
11. ARMAZENAMENTO DE DADOS INDUSTRIAIS	20
12. DESCARTE DE LOGS OPERACIONAIS	21
13. POLÍTICA DE SENHAS PARA OPERADORES	23
14. USO RESTRITO DE REDES SOCIAIS	24
15. PLANO DE RESPOSTA A INCIDENTES	25
16. DISPOSIÇÕES FINAIS	28
17. REFERÊNCIAS	30

Política de Segurança da Informação

1. INTRODUÇÃO

Fundada em 1998 em Joinville, a **Tuboplast** nasceu da visão empreendedora de Reinaldo Metz, um engenheiro mecânico que identificou a crescente demanda por tubulações industriais no polo manufatureiro catarinense. O que começou como uma pequena fábrica tornou-se, ao longo de décadas, uma referência no setor de transformação de plásticos. Atualmente, a Tuboplast é considerada uma empresa de médio porte, atendendo clientes em diferentes regiões do país, e, com esse crescimento, as informações e os recursos tecnológicos da empresa passaram a constituir ativos essenciais para a continuidade das suas operações industriais, administrativas e comerciais.

As informações e os recursos tecnológicos da **Tuboplast** constituem ativos essenciais para a continuidade das operações industriais, administrativas e comerciais da organização, sendo fundamentais para a fabricação de tubos, monitoramento dos processos produtivos. Considerando a crescente digitalização desses processos e a integração entre sistemas corporativos, tecnologias de automação industrial (TA) e dispositivos de Internet das Coisas (IoT), torna-se indispensável a adoção de mecanismos adequados de proteção dos ativos informacionais, visando reduzir riscos operacionais, financeiros, legais e reputacionais.

Esta Política de Segurança da Informação estabelece os princípios, responsabilidades, controles e requisitos necessários para proteger os ativos da **TuboPlast** contra ameaças internas e externas, garantindo a continuidade operacional e a conformidade legal. Sua elaboração é fundamentada nas normas **ISO/IEC 27001:2022, ISO/IEC 27002:2022, ISO/IEC 27005:2022** assegurando alinhamento às melhores práticas de segurança da informação.

O cumprimento desta política é obrigatório para todos os **colaboradores, terceiros, fornecedores e demais usuários** autorizados dos recursos de informação da organização.

2. OBJETIVOS

Esta Política tem por objetivo:

- a) Definir os princípios de segurança da informação da **TuboPlast**, a fim de proteger seus ativos tangíveis e intangíveis, incluindo dados operacionais, propriedade intelectual, sistemas de controle industrial e informações de processos produtivos;
- b) Servir de fundamento para as diretrizes, normas e processos relacionados à garantia da segurança da informação em todos os ambientes da empresa, abrangendo os ambientes corporativos, de chão de fábrica (OT/ICS) e de tecnologia da informação (TI);
- c) Estabelecer as responsabilidades e os limites de atuação dos colaboradores da **TuboPlast** e de terceiros em relação à segurança da informação, reforçando a cultura interna e priorizando as ações necessárias em conformidade com os objetivos do negócio e requisitos aplicáveis;
- d) Assegurar a continuidade das operações industriais e a integridade dos sistemas de produção, prevenindo incidentes de segurança que possam comprometer a disponibilidade dos processos produtivos, a qualidade dos produtos ou a segurança dos colaboradores.

3. TERMOS E DEFINIÇÕES

Para fins desta Política de Segurança da Informação, aplicam-se as seguintes definições:

- a) **Segurança da Informação:** Preservação da confidencialidade, integridade, disponibilidade, autenticidade e conformidade das informações, visando proteger os ativos organizacionais contra ameaças e garantir a continuidade do negócio.
- b) **Ameaça:** Causa potencial de um incidente indesejado que pode resultar em danos à **Tuboplast**, comprometendo a confidencialidade, integridade, disponibilidade ou autenticidade das informações e dos sistemas.
- c) **Ativo:** Qualquer recurso físico, lógico ou informacional que possua valor para a **Tuboplast**.
- d) **Ativo Tangível:** Bem físico pertencente à organização, incluindo computadores, servidores, equipamentos industriais, dispositivos IoT, documentos impressos, redes e instalações.
- e) **Ativo Intangível:** Elemento não físico que possua valor para a organização, incluindo conhecimento técnico, propriedade intelectual, reputação, marca, projetos industriais, informações estratégicas e segredos comerciais.
- f) **Autenticidade:** Garantia de que uma informação, transação ou usuário é legítimo, permitindo identificar de forma inequívoca sua origem e autoria.
- g) **Colaborador:** Empregado, estagiário, aprendiz, temporário ou qualquer pessoa que mantenha vínculo profissional direto com a **Tuboplast**.

- h) **Terceiro:** Pessoa física ou jurídica contratada para prestar serviços à **Tuboplast** ou que possua acesso autorizado aos seus ativos.
- i) **Confidencialidade:** Garantia de que as informações sejam acessadas apenas por pessoas, sistemas ou processos devidamente autorizados.
- j) **Integridade:** Garantia de que as informações permaneçam completas, corretas, precisas e protegidas contra modificações não autorizadas.
- k) **Disponibilidade:** Garantia de que as informações, sistemas e recursos tecnológicos estejam acessíveis quando necessários às atividades da organização.
- l) **Conformidade:** Garantia de atendimento aos requisitos legais, regulatórios, normativos e contratuais aplicáveis à organização.
- m) **Informação:** Conjunto de dados organizados que possuem significado e valor para a organização, independentemente do meio em que estejam armazenados.
- n) **Incidente de Segurança da Informação:** Evento confirmado ou suspeito que comprometa ou tenha potencial de comprometer a confidencialidade, integridade, disponibilidade ou autenticidade das informações.
- o) **Nível de Classificação da Informação:** Categoria atribuída à informação de acordo com sua criticidade e impacto decorrente de divulgação indevida.
- p) **Risco:** Efeito da incerteza sobre os objetivos organizacionais, resultante da combinação entre probabilidade de ocorrência de uma ameaça e seu impacto potencial.
- q) **Vulnerabilidade:** Fraqueza existente em processos, sistemas, equipamentos ou pessoas que possa ser explorada por uma ameaça.
- r) **Recursos de Tecnologia da Informação (TI):** Conjunto de equipamentos, softwares, serviços e infraestrutura utilizados para armazenamento, processamento, transmissão e proteção das informações corporativas.
- s) **Backup:** cópia de segurança de dados ou arquivos, armazenada em local separado do original, com o objetivo de permitir a recuperação das informações em caso de perda, falha, exclusão acidental ou desastre.
- t) **Recursos de Tecnologia de Automação (TA):** Conjunto de sistemas utilizados para monitoramento, supervisão, controle e automação dos processos produtivos da **Tuboplast**. Incluem:
 - PLCs;
 - SCADA;
 - IHMs;
 - Redes industriais;
 - Controladores industriais.
- u) **Recursos de Internet das Coisas (IoT):** Dispositivos inteligentes conectados à rede capazes de coletar, transmitir ou processar dados automaticamente. Incluem:
 - Sensores de temperatura;
 - Sensores de pressão;
 - Sensores de vibração;
 - Medidores inteligentes;
 - Dispositivos de manutenção preditiva.

- v) **Recurso de Informação:** Conjunto formado pelos recursos de TI, TA, IoT e pelas informações processadas, armazenadas ou transmitidas por eles.
- w) **Violação da Segurança da Informação:** Qualquer ato ou omissão que resulte no descumprimento desta Política, dos procedimentos internos ou dos controles de segurança estabelecidos pela organização.

4. PRINCÍPIOS DA SEGURANÇA DA INFORMAÇÃO

A **Tuboplast** adota os seguintes princípios gerais de segurança da informação:

- a) Preservar e proteger as informações e os recursos de informação da TuboPlast ou de terceiros, ou que estejam sob sua responsabilidade, dos diversos tipos de ameaça e em todo o seu ciclo de vida, independentemente do suporte ou formato em que se encontrem, incluindo dados de processos produtivos, especificações técnicas de produtos, informações de clientes e fornecedores;
- b) Prevenir, monitorar, identificar e responder aos incidentes de segurança da informação, reduzindo seus impactos e assegurando a **confidencialidade, integridade, disponibilidade e autenticidade** das informações, bem como a conformidade no uso dos recursos de informação no desenvolvimento das atividades profissionais e operacionais;
- c) Garantir a segurança da informação nos ambientes de tecnologia da informação (TI) e nos ambientes operacionais de chão de fábrica, protegendo sistemas, equipamentos e dados críticos vinculados ao processo de fabricação de tubos e conexões;
- d) Cumprir a legislação vigente no Brasil e demais instrumentos regulamentares relacionados ao negócio no que diz respeito à segurança da informação e aos objetivos corporativos, morais e éticos da **TuboPlast**.

As medidas de prevenção e controle adotadas pela **TuboPlast** têm como propósito fundamental gerenciar os riscos de segurança da informação, mantendo-os em níveis compatíveis com as necessidades e objetivos do negócio.

5. PAPÉIS E RESPONSABILIDADES

A efetividade da segurança da informação na **TuboPlast** depende do comprometimento e da atuação responsável de todos os envolvidos nas atividades da organização. Cada colaborador, independentemente do nível hierárquico ou função exercida, possui responsabilidades específicas no que diz respeito à proteção dos ativos de informação. São eles:

Diretoria

À Diretoria compete o papel de patrocinadora da segurança da informação na TuboPlast, sendo responsável por:

- a) Aprovar esta Política e suas revisões periódicas;

- b) Garantir a alocação dos recursos humanos, financeiros e tecnológicos necessários para a sua implementação e manutenção.

Gestor de TI

O Gestor de Tecnologia da Informação é o responsável técnico pela operacionalização dos controles de segurança, cabendo-lhe:

- a) Administrar e monitorar os controles tecnológicos de segurança da informação;
- b) Gerenciar os acessos lógicos aos sistemas e recursos corporativos;
- c) Coordenar o processo de resposta a incidentes de segurança da informação, garantindo o registro, a análise e o tratamento adequados.

Supervisores de Produção

Os Supervisores de Produção atuam como responsáveis pela conformidade da política no ambiente operacional, devendo:

- a) Garantir o cumprimento desta Política na área industrial sob sua responsabilidade;
- b) Aprovar e controlar os acessos operacionais aos sistemas e equipamentos de automação industrial.

Colaboradores

Os operadores são responsáveis pelo uso seguro e adequado dos recursos de informação no exercício de suas atividades, devendo:

- a) Utilizar exclusivamente credenciais individuais e intransferíveis para acesso aos sistemas;
- b) Seguir rigorosamente os procedimentos de segurança estabelecidos para o ambiente operacional.

Terceiros

Prestadores de serviço, fornecedores e demais terceiros que tenham acesso a informações ou sistemas da **TuboPlast** devem:

- a) Assinar o Termo de Confidencialidade antes do início de qualquer atividade;
- b) Cumprir integralmente as disposições desta Política e das normas internas de segurança da informação vigentes.

6. VIOLAÇÕES E GRAU DE RESPONSABILIDADE

As violações desta Política serão classificadas conforme sua gravidade, sujeitando o infrator às sanções disciplinares proporcionais ao grau da conduta, sem prejuízo das responsabilidades nas esferas cível e criminal, nos termos da legislação vigente. Sendo as sanções:

Grau	Sanção	Exemplos de Infrações	Reincidência
Grau I	Advertência Formal	Compartilhamento de senha; deixar documentos físicos expostos; ausência de bloqueio de estação de trabalho.	Escalada para Grau II
Grau II	Medidas Disciplinares (Suspensão de acessos e Realocação de Função)	Acesso a área restrita sem autorização; instalação de software não autorizado; descumprimento reiterado das normas desta Política.	Escalada para Grau III
Grau III	Suspensão sem Remuneração	Tentativa de burlar controles de segurança; acesso não autorizado a sistemas ou dados sensíveis; alteração indevida de parâmetros industriais.	Escalada para Grau IV
Grau IV	Demissão por Justa Causa	Sabotagem de sistemas; vazamento intencional de informações confidenciais; atos que causem dano grave à organização, podendo implicar responsabilização cível e criminal.	Rescisão imediata e medidas legais cabíveis

Tabela 1 – Graus de Violação e Sanções Disciplinares da TuboPlast

A classificação e o enquadramento das infrações nos graus estabelecidos nesta Política são de responsabilidade do líder ou supervisor imediato do colaborador envolvido, em conjunto com o setor de Recursos Humanos, considerando o contexto, a gravidade e os impactos da conduta.

As violações desta Política sujeitarão o infrator às medidas disciplinares previstas no regulamento interno da **TuboPlast**, podendo, conforme a gravidade, implicar em rescisão contratual e responsabilização nas esferas cível e criminal, nos termos da legislação vigente.

7. INVENTÁRIO DE ATIVOS

Para garantir a proteção adequada dos recursos da **TuboPlast**, é necessário identificar e classificar os ativos sujeitos às diretrizes desta Política. A tabela a seguir apresenta os ativos de informação e tecnologia sob responsabilidade da organização, agrupados por categoria, que devem ser protegidos contra ameaças e utilizados em conformidade com os controles estabelecidos.

Categoria	Ativo
5.1 Ativos de Tecnologia da Informação (TI)	
TI	Servidores corporativos
	ERP
	Banco de dados
	Correio eletrônico
	Computadores corporativos
	Infraestrutura de rede
5.2 Ativos de Tecnologia de Automação (TA)	
TA	PLCs
	Sistemas SCADA
	IHMs
	Controladores industriais
	Redes industriais
	Sistemas supervisórios
5.3 Ativos IoT	
IoT	Sensores de temperatura
	Sensores de pressão
	Sensores de vibração
	Medidores inteligentes
	Gateways IoT
5.4 Ativos de Informação	
Informação	Dados de produção
	Ordens de fabricação ou OP
	Projetos industriais
	Dados financeiros

	Informações de clientes
	Dados de fornecedores

Tabela 2 – Classificação dos Ativos de Informação e Tecnologia da TuboPlast

8. INVENTÁRIO DE ATIVOS CRÍTICOS

Dentre os ativos identificados, aqueles que apresentam maior impacto potencial sobre a continuidade operacional, a segurança dos processos industriais e a integridade das informações da **TuboPlast** são classificados como ativos críticos. O inventário a seguir elenca esses ativos, indicando sua categoria e nível de criticidade, servindo como referência prioritária para a aplicação dos controles de segurança da informação.

Ativo	Categoria	Criticidade
ERP Corporativo	TI	Alta
Banco de Dados	TI	Alta
Servidor de Produção	TI	Alta
PLCs	TA	Crítica
Sistema SCADA	TA	Crítica
Sensores IoT	IoT	Alta
Firewall Industrial	TA	Crítica
Backups Industriais	TI	Crítica
Rede Industrial	TA	Crítica
Dados de Produção	Informação	Crítica

Tabela 3 – Inventário de Ativos Críticos da TuboPlast

Legenda:

Criticidade	Descrição
Crítica	Ativo cuja indisponibilidade ou comprometimento causa impacto severo e imediato às operações.
Alta	Ativo cuja indisponibilidade causa impacto significativo, com possibilidade de recuperação em curto prazo.

9. CONTEXTO ORGANIZACIONAL

A **Tuboplast** atua na fabricação de tubos industriais utilizando processos automatizados e equipamentos conectados à internet para monitoramento remoto, manutenção preditiva e controle operacional.

A empresa utiliza sistemas corporativos integrados ao ambiente industrial, permitindo o compartilhamento de informações entre os setores administrativos e produtivos.

Essa integração proporciona ganhos operacionais, porém aumenta a exposição a ameaças como:

- Ataques ransomware;
- Acessos não autorizados;
- Sabotagem industrial;
- Vazamento de informações;
- Falhas em dispositivos IoT;
- Interrupção de produção;
- Manipulação indevida de parâmetros industriais.

Diante desse cenário, a segurança da informação torna-se um requisito estratégico para a continuidade do negócio.

10. CONTROLES DE SEGURANÇA DA INFORMAÇÃO

Com o objetivo de proteger seus ativos tecnológicos, operacionais e informacionais contra ameaças internas e externas, considerando a integração entre os ambientes corporativos de TI, os sistemas de automação industrial, os controles aqui estabelecidos abrangem tanto o ambiente administrativo quanto o chão de fábrica, garantindo a confidencialidade, integridade, disponibilidade e autenticidade das informações em todo o ciclo operacional da organização.

10.1. DO CONTROLE DE ACESSO FÍSICO

Os controles de acesso físico aqui estabelecidos têm por objetivo restringir o ingresso às dependências e ambientes da TuboPlast a pessoas devidamente autorizadas, prevenindo acessos não autorizados, furtos, sabotagens e demais incidentes de segurança de natureza física. Estes controles fundamentam-se nos seguintes referenciais normativos: **ISO/IEC 27001:2022** — Anexo A, controles de segurança física e do ambiente; **ISO/IEC 27002:2022** — Seção 7, que trata especificamente de controles físicos, incluindo perímetros de segurança física (7.1), controle de entrada física (7.2), segurança de escritórios, salas e instalações (7.3) e trabalho em áreas seguras (7.4).

As infrações aos controles de acesso físico serão enquadradas conforme os graus a seguir, observando o disposto na Seção 6 deste documento.

DO ACESSO FÍSICO À PLANTA INDUSTRIAL

Entrada de Funcionários

O acesso de colaboradores à planta industrial ocorre pela primeira guarita, mediante passagem por catraca habilitada com reconhecimento facial. O cadastro biométrico é realizado automaticamente após a emissão do crachá de identificação, condicionado à requisição formal junto ao setor de RH.

Entrada de Funcionários com Veículos

O acesso de veículos de colaboradores ocorre por guarita exclusiva, mediante apresentação de crachá de identificação. Após o ingresso na planta industrial, o colaborador deve obrigatoriamente realizar o reconhecimento facial na catraca de acesso interno antes de seguir para sua área de atuação.

Entrada de Terceiros, Prestadores de Serviço, Fornecedores e Visitantes

O acesso ocorre pela primeira guarita, onde o visitante deve se identificar pessoalmente ao guarda e preencher a ficha de visitantes, constando, sem falta:

- nome completo;
- número do documento de identificação(RG ou CPF);
- nome do colaborador responsável e setor;
- finalidade da visita; e
- tempo previsto de permanência.

A ficha é registrada no sistema de controle de acesso da guarita, caso seja o primeiro acesso. O guarda realiza chamada ao ramal do colaborador responsável para confirmação da visita, sendo obrigatória a presença do responsável para receber e acompanhar o visitante durante toda a permanência nas dependências da empresa. A saída deve ser verificada pelo guarda no horário previamente especificado na ficha, com confirmação pelo colaborador responsável.

Entrada de Terceiros com Veículos

O acesso de veículos de terceiros ocorre por guarita exclusiva, mediante apresentação de documento de identificação e registro do veículo. A entrada só é liberada após confirmação da visita junto ao setor responsável.

Em caso de Perda ou Extravio do Crachá

O colaborador deve comunicar imediatamente ao setor de RH ou TI, que procederá ao bloqueio imediato do crachá no sistema. Um novo crachá será emitido mediante solicitação formal, podendo ser cobrada taxa administrativa. **O crachá extraviado não poderá ser reativado em hipótese alguma.**

Desligamento de Funcionário

Em caso de desligamento do funcionário, seja por demissão, encerramento de contrato ou qualquer outro motivo, devem ser adotadas imediatamente as seguintes medidas:

- O crachá de identificação deve ser recolhido pelo setor de Recursos Humanos no ato do desligamento, sendo encaminhado ao setor de TI para bloqueio e inativação imediata no sistema de controle de acesso, incluindo o cancelamento do cadastro biométrico de reconhecimento facial.
- O acesso aos sistemas corporativos, redes e demais recursos de informação deve ser revogado pelo setor de TI no mesmo dia do desligamento, conforme previsto na seção de controle de acessos lógicos desta Política.
- O colaborador desligado não poderá permanecer nas dependências da empresa após a conclusão do processo de desligamento, devendo ser acompanhado até a saída por um representante responsável do setor.

Casos de desligamento por justa causa ou situações de risco **devem ser comunicados previamente ao setor de TI e à segurança patrimonial**, para que os bloqueios sejam realizados antes da comunicação formal ao funcionário.

DO ACESSO FÍSICO À FÁBRICA

Entrada de Funcionários

O acesso de colaboradores à fábrica é liberado mediante registro de ponto de entrada, utilizando crachá com identificador único de matrícula. O registro é obrigatório a cada entrada e saída do ambiente fabril, garantindo o rastreamento da presença de colaboradores nas dependências industriais.

Áreas de Acesso Restrito

As áreas de **Controle de Qualidade e Expedição** são classificadas como de acesso restrito dentro do ambiente fabril. O acesso é liberado exclusivamente por meio de crachá habilitado, com abertura eletrônica de porta, sendo as entradas sinalizadas com placas de aviso de acesso restrito. Apenas colaboradores com perfil de acesso previamente autorizado pelo supervisor responsável poderão transitar nessas áreas.

Exceções de Acesso

O acesso de colaboradores não habilitados às áreas restritas somente será permitido em caráter excepcional, mediante autorização formal e prévia do supervisor responsável pela área. O colaborador autorizado deverá ser acompanhado por um funcionário habilitado durante toda a permanência na área restrita. Toda exceção de acesso deve ser registrada no sistema de

controle de acesso, com identificação do solicitante, do autorizador, da finalidade e do período de permanência.

DO ACESSO FÍSICO AO SETOR DE ADMINISTRAÇÃO(MEZANINO)

Entrada de Funcionários

O acesso de colaboradores ao setor administrativo é realizado mediante registro de entrada com crachá de identificador único de matrícula. O registro é obrigatório a cada entrada e saída do ambiente, garantindo o rastreamento da presença de colaboradores na área.

Terceiros

O acesso de terceiros ao setor administrativo é permitido exclusivamente quando acompanhados por um colaborador responsável previamente identificado, seguindo os mesmos procedimentos definidos no controle de acesso à planta industrial. Conforme Seção — Do Acesso Físico à Planta Industrial deste documento.

Controle de Acesso à Documentação Física

Toda documentação física de caráter administrativo, financeiro, contratual ou estratégico deve ser mantida em local controlado, preferencialmente em armários ou arquivos com chave, sob responsabilidade do gestor da área. O acesso a documentos físicos é permitido apenas a colaboradores autorizados pelo gestor responsável. A retirada de documentos do setor deve ser registrada em formulário próprio, constando identificação do colaborador, documento retirado, finalidade e prazo de devolução. Documentos que contenham informações sensíveis não podem ser deixados sobre mesas ou em locais de livre acesso, devendo ser guardados ao término do expediente ou sempre que o colaborador se ausentar do posto de trabalho. O descarte de documentos físicos deve ser realizado por meio de fragmentação, sendo vedado o descarte em lixo comum.

DO ACESSO FÍSICO AO SETOR DE ENGENHARIA

Entrada de Funcionários

O acesso de colaboradores ao setor de engenharia é realizado mediante registro de ponto de entrada com crachá de identificador único de matrícula.

Áreas de Acesso Restrito

As áreas de Engenharia de Produto, Engenharia de Processo e Manutenção são classificadas como de acesso restrito dentro do setor. O acesso é liberado exclusivamente por meio de crachá habilitado, com abertura eletrônica de porta, sendo as entradas sinalizadas com placas

de aviso de acesso restrito. Apenas colaboradores com perfil de acesso previamente autorizado pelo supervisor responsável poderão transitar nessas áreas.

Controle de Acesso à Documentação Confidencial

Projetos industriais, especificações técnicas de produto, parâmetros de processo e demais documentos de engenharia são classificados como ativos intangíveis de alto valor para a **TuboPlast**. Toda documentação técnica deve ser armazenada em local físico controlado, com acesso restrito aos colaboradores autorizados pelo gestor da área. A reprodução, cópia ou retirada de documentos técnicos do setor deve ser formalmente autorizada pelo responsável pela área de engenharia e registrada em formulário de controle. O descarte de documentos técnicos deve ser realizado exclusivamente por fragmentação.

Controle de Acesso da Manutenção

Em razão do acesso direto aos equipamentos, máquinas e sistemas de automação industrial, os colaboradores do setor de manutenção estão sujeitos a alto nível de supervisão. Toda intervenção em equipamentos ou sistemas deve ser previamente autorizada pelo supervisor de manutenção e registrada em ordem de serviço, constando identificação do colaborador, equipamento ou sistema acessado, natureza da intervenção e horário de início e término. Intervenções em sistemas de automação industrial (PLCs, SCADA, IHMs) devem ser comunicadas previamente ao setor de TI. O acesso não supervisionado de colaboradores da manutenção a áreas restritas fora do horário regular deve ser **formalmente autorizado e monitorado**.

Terceiros

O acesso de terceiros ao setor de engenharia é permitido exclusivamente mediante autorização prévia do gestor responsável e com acompanhamento de um colaborador habilitado durante toda a permanência na área. Conforme Seção — Do Acesso Físico à Planta Industrial deste documento.

DO ACESSO FÍSICO AO SETOR DE TECNOLOGIA DA INFORMAÇÃO(TI)

Entrada de Funcionários

O acesso ao setor de TI é restrito exclusivamente aos colaboradores com vínculo de trabalho formal junto ao setor. O ingresso ocorre por porta com abertura eletrônica mediante crachá habilitado, sendo a entrada sinalizada com placa de acesso restrito. O ambiente é monitorado por câmeras de segurança em operação contínua.

Terceiros

O acesso de terceiros ao setor de TI é permitido exclusivamente mediante autorização prévia formal do gestor de TI, com acompanhamento obrigatório de um colaborador do setor durante

toda a permanência. O acesso deve ser registrado no sistema de controle de acesso com identificação do visitante, finalidade, autorizador e período de permanência. Conforme Seção — Do Acesso Físico à Planta Industrial deste documento.

Hierarquia de Acesso aos Ativos Críticos

Da Sala de Servidores: Classificada como ativo de criticidade máxima na PSI, a sala de servidores possui controle de acesso independente, restrito ao Gestor de TI e aos colaboradores do setor de Tecnologia da Informação por ele formalmente autorizados. Qualquer acesso deve ser previamente registrado e justificado. O acesso não planejado ou de emergência deve ser comunicado ao Gestor de TI imediatamente após sua ocorrência e devidamente documentado.

Dos Backups: O acesso físico às mídias e equipamentos de backup é restrito ao Gestor de TI e ao colaborador responsável pela rotina de backup. A retirada de mídias de backup do ambiente deve ser formalmente autorizada pelo Gestor de TI e registrada, constando identificação, finalidade e prazo de retorno ou descarte seguro.

Do Firewall Industrial: O acesso físico ao firewall industrial é restrito ao restrito ao Gestor de TI e aos colaboradores do setor de Tecnologia da Informação por ele formalmente autorizados. Qualquer intervenção no equipamento deve ser registrada em ordem de serviço, com descrição da atividade realizada, data, horário e identificação do responsável. Intervenções realizadas por terceiros, como fornecedores ou prestadores de suporte, devem ser previamente autorizadas pelo Gestor de TI e acompanhadas por um colaborador do setor durante toda a execução.

Da Rede Industrial: O acesso físico aos equipamentos que compõem a rede industrial, responsável pela integração entre o ambiente de TI corporativo e o chão de fábrica, é restrito ao Gestor de TI e aos colaboradores do setor de Tecnologia da Informação por ele formalmente autorizados, sendo previamente comunicado ao supervisor de produção quando envolver intervenções que possam impactar os sistemas de automação. Toda manutenção ou alteração na rede industrial deve ser registrada, com identificação do responsável, descrição da intervenção e confirmação de que os sistemas produtivos não foram comprometidos.

Versão	Data	Responsável	Aprovado por/Data	Vigência
1.0	12/06/2026	TI / Segurança da Informação	Ian Costa - Diretoria Executiva em 12/06/2026	12/06/2026 - indeterminado

10.2. DO CONTROLE DE ACESSO LÓGICO

O controle de acesso lógico da **TuboPlast** tem por objetivo garantir que apenas usuários devidamente autorizados possam acessar sistemas, redes, dados e recursos de informação, de

acordo com suas atribuições e necessidades operacionais. Os controles aqui estabelecidos atendem diretamente aos princípios de confidencialidade, assegurando que as informações sejam acessadas somente por quem de direito, e de integridade, prevenindo alterações não autorizadas nos dados e sistemas da organização. O acesso lógico é gerenciado pelo setor de Tecnologia da Informação e segue o princípio do menor privilégio, concedendo a cada usuário apenas as permissões estritamente necessárias ao exercício de suas funções. Estes controles fundamentam-se nos seguintes referenciais normativos: **ISO/IEC 27001:2022** — Anexo A, controles de gestão de identidades e acessos; **ISO/IEC 27002:2022** — Seção 5 e Seção 8, especialmente os controles 5.15 (controle de acesso), 5.16 (gestão de identidades), 5.17 (informações de autenticação), 5.18 (direitos de acesso) e 8.2 (direitos de acesso privilegiado); **ISO/IEC 27005:2022** — tratamento dos riscos de acesso não autorizado e manipulação indevida de sistemas identificados no contexto organizacional.

As infrações aos controles de acesso lógico serão enquadradas conforme os graus a seguir, observando o disposto na Seção 6 deste documento:

DO ACESSO LÓGICO AO SETOR DE ADMINISTRAÇÃO(MEZANINO)

Colaboradores

Os colaboradores do setor administrativo recebem credencial individual criada pelo setor de TI no momento do ingresso na função, com perfil de acesso configurado conforme o cargo exercido. O acesso abrange os seguintes sistemas, conforme a necessidade de cada função:

- ERP corporativo — módulos pertinentes à função (financeiro, compras, vendas, RH);
- Correio eletrônico corporativo;
- Pastas e arquivos na rede interna, restritos ao escopo do setor;
- Ferramentas administrativas internas.

O acesso a módulos ou informações de outros setores somente é permitido mediante solicitação formal do gestor responsável ao setor de TI, **com justificativa e prazo definidos**. Toda tentativa de acesso a recursos não autorizados é registrada automaticamente pelo sistema e reportada ao Gestor de TI.

Terceiros

Terceiros com necessidade de acesso temporário a sistemas administrativos recebem credencial temporária emitida pelo Setor de Tecnologia da Informação, com escopo restrito aos sistemas estritamente necessários à atividade, prazo de validade definido e revogação automática ao término do período autorizado. O acesso temporário deve ser solicitado formalmente pelo colaborador responsável pelo terceiro com antecedência mínima de um dia útil. Em situações de urgência operacional devidamente justificadas, o prazo poderá ser dispensado mediante autorização expressa do Gestor de TI, com registro formal da ocorrência.

DO ACESSO LÓGICO AO SETOR DE ENGENHARIA

Colaboradores — Engenharia de Produto e Processo

Os colaboradores das áreas de Engenharia de Produto e Engenharia de Processo recebem acesso lógico restrito aos sistemas e repositórios pertinentes à sua área de atuação, incluindo:

- Sistema de gestão de projetos e desenhos técnicos;
- Repositório de especificações técnicas de produto;
- Parâmetros e receitas de processo;
- ERP — módulos de engenharia.

O acesso a projetos industriais e especificações técnicas é registrado em log, identificando o usuário, o documento acessado, a data e o horário. A exportação, impressão ou compartilhamento de documentos técnicos deve ser formalmente autorizada pelo gestor da área e registrada. O acesso de um colaborador de Engenharia de Produto aos sistemas de Engenharia de Processo e vice-versa somente é permitido mediante autorização prévia do gestor responsável.

Colaboradores — Manutenção

Os colaboradores do setor de manutenção possuem acesso lógico restrito ao sistema de ordens de serviço e, quando necessário à execução de suas atividades, aos sistemas de automação industrial sob supervisão. O acesso a PLCs, SCADA e IHMs é registrado automaticamente pelo sistema, com identificação do usuário, equipamento acessado, data, horário de início e término e ações realizadas. Alterações em parâmetros industriais somente podem ser realizadas mediante autorização prévia do supervisor de manutenção, registrada em ordem de serviço. O acesso remoto a sistemas de automação por colaboradores da manutenção é vedado, sendo permitido apenas o acesso local e supervisionado.

Terceiros

Prestadores de serviço e fornecedores com necessidade de acesso lógico a sistemas de engenharia recebem credencial temporária com escopo estritamente definido pelo gestor da área e emitida pelo Setor de Tecnologia da Informação. O acesso é monitorado em tempo real por um colaborador do setor durante toda a sessão, e a credencial é revogada imediatamente ao término da atividade. Todo acesso de terceiro a sistemas de engenharia deve ser previamente comunicado ao Gestor de TI.

DO ACESSO LÓGICO AO SETOR DE TECNOLOGIA DA INFORMAÇÃO

Colaboradores — Hierarquia de Acesso

O acesso lógico aos sistemas e infraestrutura de TI obedece à seguinte hierarquia, com perfis de permissão definidos conforme a função exercida:

Gestor de TI: possui acesso irrestrito a todos os sistemas, redes, servidores, backups, firewall industrial e rede industrial, sendo o único usuário com privilégio de administrador global. Todas as ações realizadas com perfil de administrador são registradas em log com identificação, data, horário e descrição da ação.

Analistas de TI: possuem acesso aos sistemas e infraestrutura pertinentes à sua área de atuação, sem privilégio de administrador global. Alterações em configurações críticas dependem de autorização prévia do Gestor de TI, sendo registradas em log e documentadas em ordem de serviço.

Técnicos de Suporte: possuem acesso restrito aos sistemas de suporte ao usuário e às estações de trabalho corporativas, sem acesso a servidores, backups ou infraestrutura de rede. O acesso remoto às estações dos usuários para fins de suporte deve ser previamente autorizado pelo usuário e registrado.

Sala de Servidores — Acesso Lógico

O acesso remoto aos servidores é permitido exclusivamente a usuários autorizados pelo Gestor de TI, mediante autenticação em dois fatores. Toda sessão remota é registrada em log, contendo identificação do usuário, endereço de origem, data, horário de início e término e ações realizadas. O acesso remoto fora do horário regular deve ser previamente comunicado ao Gestor de TI e registrado com justificativa.

Dos Backups: O acesso lógico às rotinas, arquivos e sistemas de backup é restrito ao Gestor de TI e ao colaborador formalmente designado para a rotina de backup. A execução de restauração de backup deve ser formalmente autorizada pelo Gestor de TI, com registro da justificativa, escopo da restauração, data e identificação do responsável. O histórico de backups realizados e restaurações efetuadas deve ser mantido pelo período mínimo de 12 meses.

Do Firewall Industrial: Alterações nas regras e configurações do firewall industrial são de competência exclusiva do Gestor de TI. Toda alteração deve ser previamente documentada, contendo descrição da mudança, justificativa, impacto esperado, data e identificação do responsável. As configurações vigentes do firewall devem ser revisadas pelo Gestor de TI com frequência mínima trimestral.

Rede Industrial: O acesso lógico aos equipamentos que compõem a rede industrial é restrito ao Gestor de TI. Qualquer intervenção de configuração na rede industrial deve ser previamente comunicada ao supervisor de produção quando houver risco de impacto nos sistemas de automação, e registrada com identificação do responsável, descrição da intervenção e confirmação de que os sistemas produtivos não foram comprometidos.

Terceiros

O acesso lógico de terceiros ao ambiente de TI é permitido exclusivamente mediante credencial temporária emitida pelo Setor de Tecnologia da Informação, com escopo estritamente definido e prazo de validade determinado. O acesso é monitorado em tempo real pelo Gestor de TI ou por colaborador do setor por ele designado durante toda a sessão. A credencial é revogada imediatamente ao término da atividade, sendo vedada qualquer prorrogação sem nova solicitação formal.

Revisão Periódica de Acessos

O Gestor de TI deve realizar revisão formal dos perfis de acesso lógico de todos os usuários com frequência mínima semestral, verificando a adequação das permissões concedidas às funções exercidas. Os resultados da revisão devem ser documentados e eventuais acessos indevidos devem ser revogados imediatamente. Em caso de mudança de função, afastamento prolongado ou desligamento, os acessos lógicos devem ser revisados ou revogados conforme previsto na seção xxx de Desligamento de Funcionário deste documento.

Versão	Data	Responsável	Aprovado por/Data	Vigência
1.0	12/06/2026	TI / Segurança da Informação	Ian Costa - Diretoria Executiva em 12/06/2026	12/06/2026 - indeterminado

11. ARMAZENAMENTO DE DADOS INDUSTRIAIS

Norma	Autoria	Versão	Aprovação	Vigência
Backup	João Vitor Scharmach	1.0	Gerência de T 20/12/2025	1/01/2026 - 31/01/2026

Em uma empresa são gerados milhares de dados por segundo e além de processados esses dados também necessitam serem armazenados de forma correta, segura e em escala industrial.

Com base na iso 27002:

Seção 5.33 Proteção de registros.

Seção 8.13 Backup das informações

Seção 8.24 Uso de criptografia

Se faz necessário a classificação e separação dos dados pela sua criticidade assim. Todos os dados com alto nível de criticidade são colocados em uma rotina de backup para assim serem protegidos contra perdas, destruição, falsificação, acesso não autorizado e liberação não autorizada.

Em conjunto com a realização de testes de verificação de backup em intervalos regulares cada vez menores, quanto mais alta a criticidade dos dados apresentada.

Além de todos os dados armazenados devem ser criptografados com o modelo AES-256 que utiliza criptografia simétrica considerada praticamente impenetrável, porque utiliza uma chave de 256 bits para cifrar os seus dados.

As penalidades são:

- Grau I: Advertência Formal
- Grau II: Medidas Disciplinares (Suspensão de acessos e Realocação de Função)
- Grau III: Suspensão sem Remuneração
- Grau IV: Demissão por Justa Causa e medidas legais cabíveis

As penalidades para violação de tal política serão baseadas na infração e verificado a criticidade das informações que foram afetadas pelo não cumprimento da norma.

Não colocar criptografia nos dados, sendo descoberto o erro por pessoal interno não malicioso: Das 2 primeiras vezes advertência formal. Se persistir para uma terceira será aplicada a suspensão de acessos e Medidas disciplinares (realocação de função).

Não colocar criptografia de dados, sendo descoberto após um ataque que conseguiu capturar os dados. Primeira advertência formal seguido por suspensão de acessos e medidas disciplinares (realocação de função). Se persistir uma segunda vez todos os anteriores com adição de suspensão do serviço sem remuneração. Se ocorrer uma terceira vez, irá evoluir para um desligamento por não cumprimento sucessivo das normas dependendo da gravidade e natureza dos dados podendo evoluir para a responsabilização civil ou criminal.

Não efetuar backup dos sistemas. Descoberto sem situação de crise, com os sistemas funcionando normalmente. Advertência formal se persistir por mais duas vezes evolui para suspensão de acessos e medidas disciplinares (realocação de função).

Não efetuar backup dos sistemas. Descoberto em situação de crise, com os sistemas não funcionando normalmente. Advertência formal se ocorrer novamente, suspensão de acessos e medidas disciplinares. Se ocorrer uma terceira

vez, além das condições anteriores com a adição de Suspensão do serviço sem remuneração podendo evoluir para desligamento por não cumprimento sucessivo das normas e responsabilização civil ou criminal

12. DESCARTE DE LOGS OPERACIONAIS

Norma	Autoria	Versão	Aprovação	Vigência
Descarte de logs operacionais	Alexssandro Borges Quintino	1.3	Gerência de TI	01/02/2026 - 01/02/2027

Visando assegurar os dados registrados em logs, a empresa irá adotar o procedimento de descarte de logs. Conforme a normativa brasileira, deve-se armazenar durante um determinado período estipulado abaixo:

- 6 Meses: Prazo mínimo exigido pelo Marco Civil da Internet (Lei nº 12.965/2014) e por normativas da [LGPD e o tempo de armazenamento dos dados pessoais](#) para logs de acesso a aplicações.
- 1 a 2 Anos: Período recomendado de retenção para a maioria das organizações, permitindo a investigação de intrusões, que costumam levar meses para serem detectadas.
- 5 Anos: Usado para logs de auditoria e registros financeiros/fiscais, alinhando-se ao prazo geral de prescrição do Código Tributário Nacional.
- 7 a 10 Anos (ou superior): Obrigatório para logs de setores regulados (como saúde, ou requisitos específicos da ICP-Brasil para transações biométricas conforme a [Altera o tempo de armazenamento dos logs, trilhas de ...](#)).

Tais informações serão armazenadas e asseguradas, respeitando a normativa de armazenamento de dados. O protocolo a seguir para descarte dos dados em discos rígidos realiza a desmagnetização (degaussing) ou trituração física dos dispositivos para evitar vazamento de dados, podendo repassar os equipamentos após garantir que não há como recuperar dados a uma cooperativa de reciclagem de resíduos eletrônicos.

Em hipótese alguma deve ser descartado o equipamento sem este procedimento ou feito cópia dos dados. Em caso de reutilização de discos rígidos, pendrives ou qualquer dispositivo de armazenamento de dados, os mesmos devem ter seus dados permanentemente excluídos e reescritos, garantindo a não recuperação dos mesmos. Recomenda-se o uso de métodos como Gutmann ou DoD 5220.22-M.

Para dados que não estão armazenados em eletrônicos, dados que possivelmente foram impressos em folhas, cartazes, banners ou qualquer meio físico

devem ser destruídos sem a possibilidade de recuperação ou identificação do conteúdo.

Caso tenha uma falha no procedimento, os responsáveis estarão sujeitos às penalidades citadas abaixo:

As penalidades são:

- Grau I: Advertência Formal
- Grau II: Medidas Disciplinares (Suspensão de acessos e Realocação de Função)
- Grau III: Suspensão sem Remuneração
- Grau IV: Demissão por Justa Causa e medidas legais cabíveis

As penalidades para violação de tal política serão baseadas na infração e verificado o método da violação.

Violação por não seguir o procedimento correto leva a uma advertência. Caso ocorra novamente, medidas disciplinares e realocação para outro setor.

Violação ao não descartar, tentar copiar ou mesmo retirar qualquer equipamento, documento ou qualquer que tenha informações sobre o mesmo leva à demissão e registro aos órgãos especializados, bem como à polícia para as medidas do código penal brasileiro.

13. POLÍTICA DE SENHAS PARA OPERADORES

Norma	Autoria	Versão	Aprovação	Vigência
Controle de senhas	João Vitor Scharmach	1.3	Gerência de TI 23/05/2026	12/06/2026 - 12/12/2026

Em uma empresa são necessárias milhares de senhas e a necessidade de que todas essas senhas sejam geradas e armazenadas corretamente. Para assim proteger os ativos de entrada e saída de locais físicos, servidores de dados e maquinário.

Com base na iso 27002 seção 5.17 Informações de autenticação.

Para evitar perda de senhas, criação de senhas fracas e sem método, armazenamento das senhas sem criptografia adequada e não armazenamento de senhas. Para isso não ocorrer são aplicadas normas como a de informações de autenticação e autenticação segura.

Assim, definindo que todas as senhas geradas, devem ter 8 caracteres alfanuméricos com números, letras maiúsculas e minúsculas e caracteres especiais.

Estando com o armazenamento criptografado da empresa com o AES-256.

As penalidades são:

- Grau I: Advertência Formal
- Grau II: Medidas Disciplinares (Suspensão de acessos e Realocação de Função)
- Grau III: Suspensão sem Remuneração
- Grau IV: Demissão por Justa Causa e medidas legais cabíveis

As penalidades para violação de tal política serão baseadas na infração e verificado o método da violação.

Senhas criadas sem a criptografia adequada sendo previamente descobertas sem terem sido violadas. As 2 primeiras vezes será apenas aplicado advertência formal. Se ocorrer uma terceira vez além de uma advertência formal também será aplicado a Suspensão de acessos e Medidas disciplinares(realocação de função).

Senhas criadas sem a criptografia adequada descobertas após terem sido violadas. Primeira ocorrência ocorre a advertência formal. Se ocorrer novamente leva a suspensão de acessos e medidas disciplinares(realocação de função). Se ocorrer uma terceira vez ocorre o desligamento por não cumprimento sucessivo das normas.

14. USO RESTRITO DE REDES SOCIAIS EM ÁREAS OPERACIONAIS

Norma	Autoria	Versão	Aprovação	Vigência
Uso restrito de redes sociais em áreas operacionais	Alexssandro Borges Quintino	1.3	Gerência de TI	01/02/2026 - 01/02/2027

Por questões de segurança da empresa e dos funcionários, a empresa irá adotar uma normativa sobre o uso de redes sociais em áreas operacionais. As áreas operacionais são denominadas os setores de produção de peças onde se localizam as máquinas industriais, tais como injeção e extrusão de poliolefinicos. Contempla também o setor de qualidade, onde os operadores checam se a fabricação está conforme, e o setor logístico, o qual é responsável pelo controle e transporte de produtos e suprimentos. Tendo em vista esta característica, o setor vai abranger uma política na qual será restrito o uso de equipamentos eletrônicos, tais como smartphones, tablets ou qualquer que tenha acesso às redes sociais ou que possa

causar distrações durante o expediente. Os funcionários deverão deixar seus aparelhos eletrônicos em armários fornecidos com trancas e câmeras de monitoramento.

Para operação das máquinas e comunicação entre setores, os eletrônicos utilizados, bem como computadores, tablets ou smartphones, devem ter restrições de softwares, dos quais devem conter somente os utilizados para operação e comunicação interna e restringir adição de novos softwares. A empresa estará encarregada de fornecer equipamento aos funcionários dos quais há necessidade, bem como a todos os funcionários. Tais equipamentos terão conectividade com a rede da empresa, a qual deve restringir na própria rede as redes sociais.

Ao iniciar na empresa, devem passar por um treinamento no qual será apresentado o funcionamento dos setores e sobre as restrições sobre uso de eletrônicos indevidamente nos setores operacionais, dos quais assinaram um termo de consentimento do qual estão cientes sobre a normativa e as punições cabíveis.

Cada setor deve ter placas visíveis, de preferência na entrada ou em lugares com maior fluxo, reforçando a proibição do uso dos eletrônicos e das redes sociais.

As penalidades são:

- Grau I: Advertência Formal
- Grau II: Medidas Disciplinares (Suspensão de acessos e Realocação de Função)
- Grau III: Suspensão sem Remuneração
- Grau IV: Demissão por Justa Causa e medidas legais cabíveis

As penalidades para violação de tal política serão baseadas na infração e verificado o método da violação.

Violação de uso de redes sociais utilizando eletrônico pessoal. Advertência formal com 3 advertências formais, suspensão ao continuar, demissão.

Violação utilizando eletrônico da empresa: advertência formal, troca do aparelho utilizado, caso ocorra novamente, medidas disciplinares com realocação de função que não utilize equipamento eletrônico. Caso ainda ocorra violação, será aplicada a suspensão e a persistência será aplicada demissão.

Violação utilizando eletrônico da empresa, do qual teve seu hardware modificado, será aplicada medidas disciplinares, sendo realocado para área sem uso de equipamento eletrônico e desconto em salário para aquisição de um novo equipamento. Caso tenha uma nova ocorrência de demissão.

15. PLANO DE RESPOSTA A INCIDENTES DE SEGURANÇA

A empresa deve estabelecer procedimentos e um plano para resposta de incidentes de segurança, incluindo investigação das causas, recuperação dos

dados e contenção de danos. Para que assim quando os incidentes ocorrerem ele cause dano mínimo aos ativos físicos e tecnológicos da empresa.

São classificados como incidentes de segurança as seguintes situações:

Acesso indevido

Entrada não autorizada em perímetro restrito

Tentativa de acessar informações sem autorização necessária

Violação proposital dos controles físicos ou lógicos

Sabotagem

Interrupção forçada e não proposital nas operações

Compartilhamento de dados sensíveis

Alteração ou destruição de dados

Danos e equipamentos

Incidentes TI X IoT

Falha na comunicação entre as máquinas e o sistema.

Falha crítica nas máquinas ou no sistema

Falha humana.

Identificação

Para dar início a resposta destes incidentes é necessário começar com a identificação do problema, ela poderá ser executada de dois jeitos. O primeiro é assim que um colaborador identificar algo suspeito informar imediatamente seu gestor, equipe de recursos humanos, equipe de tecnologia da informação ou a equipe de segurança da informação dependendo do tipo da origem do comportamento suspeito.

O segundo jeito seria pelos sistemas de monitoramento automático contínuo que a empresa tem registro de log, sistemas de controle de acesso, sistemas de controle de rede e alerta de dispositivos da IoT.

Contenção

Assim que o problema foi identificado começaremos segunda etapa a contenção para assim reduzir o dano causado. Por meio de métodos como suspensão temporária de acessos, isolamento de equipamentos comprometidos e bloqueios de usuários. Nota se que apesar de ter diminuído o problema nunca um problema é resolvido na etapa de contenção. Ela é apenas um quebra galho para a situação não piorar mais.

Investigação

Diferente do passo anterior este está ligado diretamente com o passo um e não com seu antecessor. Pois agora iniciaremos a investigação do ocorrido por meio dos registros de logs, identificação da origem do incidente, identificação da extensão do incidente. Se a investigação recair para um ou alguns colaboradores específicos eles devem ser imediatamente suspensos, para assim evitar a modificação de dados assim afetando as investigações.

Recuperação

A recuperação entra depois da contenção e investigação, para fazer com que todas as máquinas ou serviços afetados sejam colocadas em funcionamento novamente ou voltar ao seu funcionamento normal. Por meio de métodos como recuperação de dados, sistemas, dispositivos IoT que foram afetados por meio dos backups disponíveis.

Lições Aprendidas

Esse passo ocorre após o solucionamento do problema. Quando todos os serviços afetados já voltaram ao seu estado anterior de funcionamento. Agora se faz necessário a elaboração de um relatório do incidente contendo descrição do incidente, causa raiz, impactos identificados, ações corretivas aplicadas, melhorias recomendadas.

Que será entregue nas mãos dos responsáveis pela criação e revisão das políticas de controle existentes, para que o mesmo incidente não volte a ocorrer.

Responsabilidades

Essa parte é responsável por definir quem ficará responsável e pelo que na próxima resposta a algum eventual novo incidente. Como por exemplo a equipe de Ti deve efetuar os passos 2,3 e 4 do plano de respostas, enquanto a equipe de segurança da

informação deve efetuar o passo 3 e 5.

Assim, com as responsabilidades bem definidas o tempo e a eficácia da resposta a um eventual novo incidente será mais rápida e mais eficiente.

Penalidades

As penalidades são as consequências do incidente. Sendo aqui que estão definidas as penalidades que serão sofridas de acordo com a gravidade da transgressões cometidas. Dividida em 5 níveis

- Grau I: Advertência Formal
- Grau II: Medidas Disciplinares (Suspensão de acessos e Realocação de Função)
- Grau III: Suspensão sem Remuneração
- Grau IV: Demissão por Justa Causa e medidas legais cabíveis

Vigência

Assim, um novo plano de resposta a incidentes é elaborado. Porém ele não pode ser elaborado e esquecido, pois assim como a tecnologia que se atualiza a cada dia as ameaças também. O que força a sempre estarmos voltando e melhorando o nosso plano, principalmente quando ocorrem grandes alterações nos sistemas, processos ou requisitos.

16. DISPOSIÇÕES FINAIS

GERAIS

O presente documento deve ser lido e interpretado sob a égide das leis brasileiras, no idioma português, em conjunto com as Normas e Procedimentos aplicáveis pela **TuboPlast**. Esta Política, bem como os demais documentos que a complementam, encontram-se disponíveis nos canais internos da **TuboPlast** ou, em caso de indisponibilidade, podem ser solicitados às áreas responsáveis por Segurança da Informação, Tecnologia da Informação ou Recursos Humanos.

Esta Política entra em vigor na data de sua aprovação pelo Comitê Executivo da **TuboPlast**, com validade indeterminada, permanecendo vigente até que seja formalmente revisada ou substituída por versão posterior, conforme os critérios estabelecidos na **Seção 11.2** deste documento.

Esta Política deverá ser observada por todos os colaboradores, prestadores de serviço, fornecedores e demais terceiros que utilizem recursos tecnológicos, informacionais ou industriais da TuboPlast, independentemente do vínculo contratual ou do nível hierárquico.

O descumprimento das diretrizes aqui estabelecidas sujeitará o infrator às medidas disciplinares aplicadas de forma proporcional à gravidade da conduta, conforme estabelecido na Seção x.x deste documento.

Esta Política deverá permanecer disponível para consulta por todos os colaboradores e terceiros autorizados, sendo de responsabilidade da área de Tecnologia da Informação garantir seu acesso por meio dos canais internos de comunicação da **TuboPlast**.

REVISÃO DESTA POLÍTICA

A presente Política de Segurança da Informação é um documento vivo e deve refletir continuamente a realidade operacional, tecnológica e regulatória da **TuboPlast**. Para tanto, deverá ser revisada nos seguintes cenários:

- a) Periodicamente, com frequência mínima anual, para verificação de sua aderência às práticas e controles vigentes;
- b) Após a ocorrência de incidentes relevantes de segurança da informação que evidenciem lacunas ou necessidade de atualização;
- c) Após mudanças significativas na infraestrutura de Tecnologia da Informação (TI), Tecnologia de Automação (TA) ou nos ativos IoT da organização;
- d) Quando houver alterações na legislação, normas técnicas ou requisitos regulatórios aplicáveis à segurança da informação.

Todas as revisões deverão ser formalmente documentadas e submetidas à aprovação da Diretoria Executiva da TuboPlast antes de sua publicação e entrada em vigor, conforme registro a seguir:

Versão	Data	Descrição da Alteração	Responsável	Aprovado por
1.0	06/2026	Emissão inicial da Política de Segurança da Informação	TI / Segurança da Informação	Diretoria Executiva

Tabela 4 – Histórico de Revisões da Política de Segurança da Informação da TuboPlast

17. REFERÊNCIAS

KANANDA, Victor. **Use AES-256 encryption to secure data**. Progress, 22 jun. 2022. Disponível em: <https://www.progress.com/blogs/use-aes-256-encryption-secure-data>. Acesso em: 12 jun. 2026.

OPENAI. ChatGPT (GPT-5.5). Disponível em: <https://chatgpt.com>. Acesso em: 11 jun. 2026.

PETERS, Sam. ISO 27002:2022 – Controle 8.15 – Registro de dados, **ISMS-online**, 2025. Disponível em: https://www-isms-online.translate.goog/iso-27002/control-8-15-logging/?_x_tr_sl=en&_x_tr_tl=pt&_x_tr_hl=pt&_x_tr_pto=tc. Acesso em: 12 jun. 2026.

ALICE. Destruição Segura de Dados: O Guia Completo. **Reciclagem Brasil**, 2025. Disponível em: <https://www.reciclagembrasil.com.br/blog/categorias/artigos/destruicao-segura-de-dados-o-guia-completo>. Acesso em: 12 jun. 2026.

Métodos e processamento de destruição/higienização de dados. **SERI**, 2022. Disponível em: <https://sustainableelectronics.org/pt/knowledge-base/permmissible-data-destruction-sanitization-methods/>. Acesso em: 12 jun. 2026.

ISO de segurança da informação: o que é, normas e benefícios. **Docusign**, 2026. Disponível em: <https://www.docusign.com/pt-br/blog/certificacao-iso-seguranca-informacao>. Acesso em: 12 jun. 2026.

HINTZBERGEN, Jule et al. **Fundamentos de Segurança da Informação: Com base na ISO 27001 e na ISO 27002**. Brasport, 2018.

Aprovada em 12 de junho de 2026 pelo Comitê Executivo da TuboPlast

Tuboplast Ltda.

Rua Blumenau, 1532 - 22º andar
89245-000 – Joinville - SC - Brasil
tuboplast.informatica@tuboplast.com
www.tuboplast.com.br